

✎ 추가 일시	2026년 8월 24일 오후 8:30
🏠 강의	개인정보보호

개인정보보호 기초 개념 정리

1. 개인정보보호란?

개인정보보호란 개인을 식별할 수 있는 정보를 안전하게 보호하고, 개인정보가 정해진 목적과 절차에 따라 적법하게 처리되도록 관리하는 것을 의미한다.

정보보안 관점에서는 개인정보를 단순히 "보호해야 하는 데이터"로 보는 것이 아니라,

- 어떤 개인정보를 수집하는가?
- 왜 수집하는가?
- 어떻게 이용하는가?
- 누구에게 제공하는가?
- 어디에 저장하는가?
- 언제 파기하는가?
- 침해사고가 발생했을 때 어떻게 대응하는가?

까지 전체 생명주기를 관리하는 것이 중요하다.

2. 개인정보의 정의

「개인정보 보호법」에서는 개인정보를 살아 있는 개인에 관한 정보로서 특정 개인을 알아볼 수 있는 정보, 다른 정보와 쉽게 결합하여 개인을 알아볼 수 있는 정보, 그리고 가명처리된 정보까지 포함하여 정의한다.

2.1 개인정보

개인을 식별할 수 있거나 다른 정보와 결합하여 개인을 식별할 수 있는 정보이다.

예시

- 이름
- 주민등록번호
- 전화번호
- 이메일 주소
- 주소
- 계정 ID
- IP 주소 등
- 사진 및 영상
- 위치정보
- 온라인 식별자

중요한 점은 정보 하나만으로 개인을 식별할 수 있는 경우뿐만 아니라 다른 정보와 쉽게 결합하여 개인을 식별할 수 있는 경우도 개인정보가 될 수 있다는 것이다.

3. 개인정보 관련 주요 용어

3.1 정보주체

처리되는 개인정보에 의해 알아볼 수 있는 사람으로서 해당 개인정보의 주체가 되는 사람이다.

예를 들어 쇼핑몰 회원의 이름, 전화번호, 주소를 쇼핑몰이 관리하고 있다면 해당 회원이 정보주체가 된다.

3.2 개인정보처리자

업무를 목적으로 개인정보파일을 운용하기 위하여 개인정보를 처리하는 공공기관, 법인, 단체 및 개인 등을 의미한다.

예:

온라인 쇼핑몰 회사가 회원의 이름, 주소, 전화번호 등을 수집하고 관리한다면 해당 회사는 개인정보처리자에 해당할 수 있다.

3.3 개인정보파일

개인정보를 쉽게 검색할 수 있도록 일정한 규칙에 따라 체계적으로 배열하거나 구성한 개인정보의 집합이다.

예:

```
회원정보 DB
├─ 회원번호
├─ 이름
├─ 이메일
├─ 전화번호
├─ 주소
└─ 가입일
```

3.4 개인정보 처리

개인정보의 처리에는 단순한 저장뿐만 아니라 다양한 행위가 포함된다.

대표적으로 다음과 같은 행위가 있다.

- 수집
- 생성
- 연계
- 기록
- 저장
- 보유
- 가공
- 검색
- 이용
- 제공
- 공개
- 정정
- 복구
- 파기

즉, 개인정보를 다루는 대부분의 행위가 개인정보 처리에 해당할 수 있다.

4. 개인정보의 생명주기

개인정보보호를 공부할 때 가장 중요한 개념 중 하나이다.

수집
↓
이용
↓
제공
↓
보관 및 관리
↓
파기

각 단계마다 보호조치가 필요하다.

4.1 수집

개인정보를 수집할 때는 필요한 개인정보인지, 적법한 처리 근거가 있는지 등을 검토해야 한다.

예:

회원가입

필요한 정보

- 이메일
- 비밀번호
- 이름

불필요한 정보

- 필요하지 않은 민감정보

보안 관점에서는 **최소한의 개인정보만 수집하는 것**이 중요하다.

4.2 이용

수집한 개인정보는 정해진 목적과 법적 근거에 따라 이용해야 한다.

예:

회원가입 목적

- 계정 생성
- 서비스 제공

수집한 정보를 아무 목적이나 사용할 수 있는 것은 아니다.

4.3 제공

개인정보를 다른 기관이나 기업 등에 제공하는 경우에도 법적 근거와 적절한 절차를 검토해야 한다.

예:

쇼핑몰



택배회사

배송을 위해

이름 / 주소 / 전화번호 제공

4.4 보관 및 관리

개인정보를 저장하는 동안에는 적절한 보안조치를 적용해야 한다.

대표적인 보안조치:

- 접근권한 관리
- 인증
- 암호화
- 접속기록 관리
- 개인정보처리시스템 보호
- 악성코드 방지
- 보안 업데이트
- 내부관리계획
- 개인정보취급자 교육

개인정보 안전성 확보조치는 개인정보의 분실·도난·유출·위조·변조·훼손 등을 방지하기 위한 기술적·관리적·물리적 보호조치를 포함한다.

4.5 파기

개인정보의 보유기간이 끝났거나 처리 목적이 달성되어 더 이상 개인정보가 필요하지 않은 경우에는 적절한 방법으로 파기하는 것이 중요하다.

단순히 데이터베이스에서 사용하지 않는 것과 파기하는 것은 다르다.

사용하지 않음 ≠ 파기

5. 개인정보 최소수집 원칙

개인정보는 서비스 제공에 필요한 범위에서 최소한으로 수집하는 것이 중요하다.

예를 들어 단순 게시판 서비스를 제공하는데 주민등록번호까지 요구한다면 과도한 개인정보 수집이 될 가능성이 있다.

보안 관점에서는 개인정보를 많이 보유할수록 다음과 같은 위험도 증가한다.

보유 개인정보 증가
↓
공격 대상 증가
↓
유출 시 피해 규모 증가

따라서 **개인정보 최소화(Data Minimization)**가 중요한 보안 원칙이다.

6. 개인정보의 안전성 확보

개인정보처리자는 개인정보를 안전하게 처리하기 위해 기술적·관리적·물리적 보호조치를 적용해야 한다.

6.1 기술적 보호조치

접근권한 관리

개인정보에 접근할 수 있는 사용자를 제한한다.

일반 직원
→ 고객 개인정보 일부 접근

관리자
→ 필요한 범위의 개인정보 접근

DB 관리자
→ DB 관리 업무 수행

모든 직원에게 관리자 권한을 부여하는 것은 위험하다.

인증

개인정보처리시스템에 접근하는 사용자의 신원을 확인한다.

예:

- ID / Password
- MFA
- 인증서
- OTP
- 생체인증

암호화

개인정보를 안전하게 보호하기 위해 암호화 기술을 사용할 수 있다.

특히 비밀번호는 일반적으로 복호화 가능한 암호화 방식으로 저장하기보다 안전한 일방향 해시 방식과 적절한 솔트 등을 이용하여 저장하는 것이 중요하다.

평문 비밀번호
↓
안전한 비밀번호 저장 처리
↓
DB 저장

접속기록 관리

개인정보처리시스템에 누가 접근했고 어떤 작업을 수행했는지 기록하고 관리하는 것이 중요하다.

예:

사용자 ID
접속 일시
접속 IP

개인정보 안전성 확보조치 관련 기준에서도 접속기록을 개인정보처리시스템 접속자의 업무 내역을 기록하는 정보로 정의한다.

7. 관리적 보호조치

기술만으로 개인정보를 보호할 수는 없다.

조직 차원의 관리체계도 필요하다.

대표적인 관리적 보호조치:

- 개인정보 보호 조직 구성
- 개인정보 보호책임자 지정
- 내부관리계획 수립
- 개인정보취급자 교육
- 개인정보 처리절차 관리
- 위험관리
- 사고 대응절차 수립
- 정기적인 점검 및 감사

개인정보 보호법 시행령의 안전성 확보조치에는 내부 관리계획의 수립·시행 및 점검, 개인정보 처리시스템 접근권한 관리 등이 포함된다.

8. 물리적 보호조치

개인정보가 저장된 서버나 장비를 물리적으로 보호하는 것도 중요하다.

예:

- 서버실 출입통제
- CCTV
- 출입기록 관리
- 잠금장치
- 보조기억매체 관리

- 재해·재난 대비

즉,

기술적 보호
+
관리적 보호
+
물리적 보호
=
개인정보 보호

9. 가명정보

가명정보는 개인정보의 일부를 삭제하거나 일부 또는 전부를 대체하여 **추가 정보를 사용하거나 결합하지 않고**는 특정 개인을 알아볼 수 없도록 처리한 정보이다.

예:

원본

이름: 홍길동
나이: 24
지역: 서울
구매금액: 500,000원

↓

가명처리

고객번호: USER_001
나이: 24
지역: 서울
구매금액: 500,000원

가명정보는 AI, 통계, 연구 등의 데이터 활용을 위해 중요한 개념이다.

다만 가명정보라고 해서 개인정보가 아닌 것은 아니다.

10. 가명정보와 익명정보의 차이

구분	개인정보	가명정보	익명정보
개인 식별	가능	추가정보 없이는 어려움	불가능
개인정보보호법상 개인 정보	O	O	원칙적으로 X
복원 가능성	-	추가정보를 통해 가능할 수 있음	개인 식별이 불가능하도록 처리
활용	제한적	연구·통계 등 활용 가능	비교적 자유로운 활용

가명정보 제도는 개인정보를 보호하면서 데이터 활용을 가능하게 하기 위한 제도이다. 개인정보보호위원회는 2026년 가명정보 처리 가이드라인을 개정하여 위험도 기반 판단 체계를 강조하고 있다.

11. 개인정보와 민감정보

모든 개인정보의 위험도가 동일한 것은 아니다.

개인정보 중에서도 유출되었을 때 개인의 사생활이나 권리에 큰 영향을 줄 수 있는 정보는 더욱 높은 수준의 보호가 필요하다.

예:

- 사상·신념
- 노동조합·정당 가입 및 탈퇴
- 정치적 견해
- 건강정보
- 성생활 관련 정보
- 유전정보
- 범죄경력자료
- 생체인식정보 등

민감한 정보는 일반적인 개인정보보다 더욱 주의해서 처리해야 한다.

12. 개인정보와 고유식별정보

고유식별정보는 개인을 고유하게 식별하기 위해 특정 개인에게 부여된 식별정보이다.

대표적인 예:

- 주민등록번호
- 여권번호
- 운전면허번호
- 외국인등록번호

특히 주민등록번호와 같은 정보는 유출될 경우 명의도용 등의 피해로 이어질 가능성이 있기 때문에 매우 중요하게 관리해야 한다.

13. 정보주체의 권리

개인정보보호에서는 개인정보처리자의 의무뿐만 아니라 **정보주체의 권리**도 중요하다.

대표적으로 다음과 같은 권리가 있다.

- 개인정보 열람 요구
- 개인정보 정정·삭제 요구
- 개인정보 처리정지 요구
- 개인정보 전송 요구 등

즉, 개인정보는 기업의 소유 데이터로만 보는 것이 아니라 **정보주체의 권리를 중심으로 관리해야 하는 데이터**라는 관점이 중요하다.

14. 개인정보 처리방침

개인정보 처리방침은 기업이나 기관이 개인정보를 어떻게 처리하고 보호하는지를 공개하는 문서이다.

일반적으로 다음과 같은 내용을 확인할 수 있다.

어떤 개인정보를 수집하는가?
↓
왜 수집하는가?
↓
얼마 동안 보관하는가?
↓
누구에게 제공하는가?
↓
어떻게 보호하는가?
↓
어떻게 파기하는가?

개인정보보호위원회는 현재 개인정보 처리방침 작성지침과 개인정보 처리방침 표준 등을 제공하고 있다.

15. 개인정보 유출

개인정보 유출은 개인정보가 개인정보처리자의 관리·통제권을 벗어나 외부로 유출되는 사고를 의미한다.

대표적인 원인:

기술적 원인

- SQL Injection
- XSS
- 파일 업로드 취약점
- 접근통제 취약점
- 관리자 페이지 노출
- 인증 우회
- 취약한 비밀번호
- 서버 취약점
- 클라우드 설정 오류

관리적 원인

- 과도한 접근권한
 - 직원 실수
 - 개인정보 보관기간 초과
 - 보안교육 부족
 - 계정 공유
 - 내부 관리체계 미흡
-

16. 개인정보 침해사고 대응

개인정보 침해사고가 발생하면 단순히 취약점을 수정하는 것에서 끝나는 것이 아니라 사고 대응 절차가 필요하다.

기본적인 흐름:

```
침해사고 탐지
↓
사고 분석
↓
피해 범위 확인
↓
추가 피해 방지
↓
복구 및 보안조치
↓
필요한 신고·통지
↓
재발 방지
```

보안 담당자 입장에서는 다음 내용을 확인하는 것이 중요하다.

- 언제 발생했는가?
- 어떤 시스템이 공격받았는가?
- 어떤 개인정보가 영향을 받았는가?
- 몇 명의 정보주체가 영향을 받았는가?
- 공격 경로는 무엇인가?
- 현재 공격이 계속되고 있는가?
- 로그와 증거가 확보되었는가?
- 추가 피해를 막았는가?

17. 개인정보 보호와 정보보안의 관계

개인정보보호와 정보보안은 비슷하지만 완전히 같은 개념은 아니다.

정보보안
→ 정보의 기밀성·무결성·가용성 보호

개인정보보호
→ 개인정보의 적법하고 안전한 처리 및 정보주체 권리 보호

예를 들어 서버에 개인정보가 저장되어 있다면,

기밀성
→ 허가받지 않은 사람이 개인정보를 볼 수 없도록 보호

무결성
→ 개인정보가 임의로 변경되지 않도록 보호

가용성
→ 필요한 사용자가 정상적으로 개인정보를 이용할 수 있도록 보호

개인정보보호
→ 수집부터 파기까지 적절한 목적과 절차에 따라 처리

따라서 정보보안 기술은 개인정보보호를 위한 중요한 수단 중 하나라고 볼 수 있다.

18. 보안 실습과 개인정보보호의 연결

지금까지 진행한 웹 해킹 실습과 개인정보보호는 직접적으로 연결된다.

SQL Injection

SQL Injection
↓
DB 접근
↓
회원정보 조회
↓
개인정보 유출

XSS

XSS
↓
사용자 세션/브라우저 공격
↓
계정 탈취 가능성
↓
개인정보 접근

취약한 비밀번호

Brute Force



계정 탈취



개인정보 접근

접근통제 취약점

일반 사용자



관리자 기능 접근



다른 사용자의 개인정보 조회

따라서 모의해킹에서는 단순히 "취약점이 존재한다"에서 끝내지 않고,

해당 취약점으로 어떤 개인정보가 침해될 수 있는가?

까지 생각하는 것이 중요하다.

19. 개인정보보호에서 자주 나오는 핵심 키워드

키워드	핵심 내용
개인정보	살아 있는 개인에 관한 식별 가능 정보
정보주체	개인정보의 주체가 되는 사람
개인정보처리자	업무 목적으로 개인정보를 처리하는 자
개인정보파일	체계적으로 구성된 개인정보 집합
처리	수집·저장·이용·제공·파기 등
가명정보	추가정보 없이는 특정 개인을 알아보기 어렵게 처리한 정보
민감정보	사생활 및 기본권 침해 가능성이 높은 정보
고유식별정보	개인을 고유하게 식별하기 위한 정보
개인정보 처리방침	개인정보 처리 방법을 공개하는 문서
접근권한	개인정보에 접근할 수 있는 권한
접속기록	개인정보처리시스템 접근 및 업무 수행 기록
암호화	개인정보를 보호하기 위한 기술적 조치
파기	보유 필요가 없어진 개인정보를 적절한 방법으로 제거

키워드	핵심 내용
개인정보 유출	개인정보가 관리·통제 범위를 벗어나는 사고
개인정보 침해사고	개인정보의 기밀성·무결성 등에 영향을 주는 사고

20. 개인정보보호 공부 순서

개인정보보호를 처음 공부한다면 다음 순서로 공부하는 것을 추천한다.

1. 개인정보의 정의
- ↓
2. 정보주체 / 개인정보처리자
- ↓
3. 개인정보 처리
- ↓
4. 개인정보 생명주기
- ↓
5. 개인정보 수집·이용·제공
- ↓
6. 정보주체의 권리
- ↓
7. 개인정보 안전성 확보조치
- ↓
8. 가명정보
- ↓
9. 개인정보 유출 및 침해사고
- ↓
10. 개인정보 처리방침
- ↓
11. 개인정보 보호 관리체계
- ↓
12. 관련 법령 및 고시

21. 보안 관점에서 기억할 핵심

개인정보보호를 공부할 때 단순히 법 조항을 암기하는 것보다 다음 질문을 습관화하는 것이 중요하다.

① 무엇을 보호하는가?

이름?
이메일?
전화번호?
주소?
계정정보?

건강정보?
위치정보?

② 왜 수집하는가?

서비스 제공에 필요한가?

③ 누가 접근할 수 있는가?

일반 사용자?
직원?
관리자?
DB 관리자?

④ 어디에 저장되는가?

DB
파일
클라우드
백업 서버
로그

⑤ 어떻게 보호하는가?

인증
접근통제
암호화
로그
모니터링

⑥ 언제 삭제하는가?

보유기간 종료
처리 목적 달성
→ 적절한 방법으로 파기

⑦ 유출되면 어떻게 대응하는가?

탐지
→ 분석
→ 차단
→ 복구
→ 신고·통지 검토
→ 재발 방지

핵심 한 줄 정리

개인정보보호는 개인정보를 단순히 "안 유출되게 하는 것"이 아니라, 개인정보의 수집부터 이용·제공·보관·파기까지 전체 생명주기를 적법하고 안전하게 관리하고 정보주체의 권리를 보호하는 것이다.

참고 자료

- 개인정보 보호법
- 개인정보 보호법 시행령
- 개인정보보호위원회 개인정보 처리 통합 안내서
- 개인정보보호위원회 개인정보의 안전성 확보조치 기준 안내서
- 개인정보보호위원회 가명정보 처리 가이드라인
- ISMS-P 인증기준

현재 개인정보보호위원회는 개인정보 처리 통합 안내서, 개인정보 처리방침 작성지침, 가명정보 처리 가이드라인, 개인정보의 안전성 확보조치 기준 안내서 등을 제공하고 있다.